

ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ ОБРАЗОВАТЕЛЬНОЕ
УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ «НАЦИОНАЛЬНЫЙ
ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ «ВЫСШАЯ ШКОЛА ЭКОНОМИКИ»

Московский институт электроники и математики им. А.Н.Тихонова

«Программирование на Python»

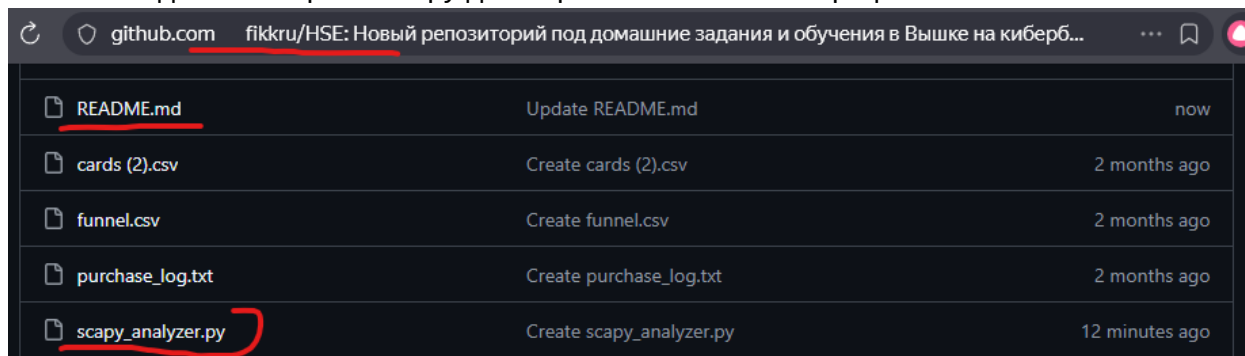
Задание по теме **Взаимодействие в WWW: взаимодействие с сервисами**

Проверил:
преп. _____
Подпись _____

Выполнил:
Мочалов Д.В.
Подпись _____

Настроен Scapy для перехвата HTTP-трафика

Мною был дописан скрипт Scapy для перехвата и анализа трафика



README.md	Update README.md	now
cards (2).csv	Create cards (2).csv	2 months ago
funnel.csv	Create funnel.csv	2 months ago
purchase_log.txt	Create purchase_log.txt	2 months ago
scapy_analyzer.py	Create scapy_analyzer.py	12 minutes ago

В основном проблема была с захватом трафика - использовал на Винде с прсар'ом

```
76 # === ИСПРАВЛЕННАЯ ЧАСТЬ ===
77 def capture_traffic(hostname, timeout=30, output_file=None):
78     packets = sniff(
79         iface="\\Device\\NPF_{loopback}",
80         filter="tcp",
81         timeout=timeout
82     )
83
84     if not output_file:
85         output_file = "gruyere.pcap"
86
87     wrpcap(output_file, packets)
88     print(f"[+] Захвачено пакетов: {len(packets)}")
89     print(f"[+] Трафик сохранён в {output_file}")
90
91     return packets
92
93
```

В интерфейсе нужно указывать свой (использовал wireshark чтобы посмотреть как точно называется мой лупбек интерфейс

Запущен Scapy и выполнен сбор трафика во время взаимодействия с сайтом Google Gruyere

```
Exit: bad_id
PS C:\Users\User> C:\Python27\python.exe C:\Users\User\Desktop\Python\maga\8\gruyere\gruyere.py

Gruyere started...
http://127.0.0.1:8008/
http://127.0.0.1:8008/409322033005719860771460597283904798102/
DANGER! Request without unique id: /608227343838907715848793691459480384213/

Exit: bad_id
PS C:\Users\User> C:\Python27\python.exe C:\Users\User\Desktop\Python\maga\8\gruyere\gruyere.py

Gruyere started...
http://127.0.0.1:8008/
http://127.0.0.1:8008/553395443002625098966819164587306044824/
miko - - [07/Feb/2026 12:39:40] "GET /553395443002625098966819164587306044824/ HTTP/1.1" 200 -
miko - - [07/Feb/2026 12:39:40] "GET /553395443002625098966819164587306044824/lib.js HTTP/1.1" 200 -
miko - - [07/Feb/2026 12:39:40] "GET /553395443002625098966819164587306044824/cheese.png HTTP/1.1" 200 -
miko - - [07/Feb/2026 12:39:40] "GET /553395443002625098966819164587306044824/ HTTP/1.1" 200 -
miko - - [07/Feb/2026 12:39:45] "GET /553395443002625098966819164587306044824/newssnippet.gtl HTTP/1.1" 200 -
miko - - [07/Feb/2026 12:40:03] "GET /553395443002625098966819164587306044824/newssnippet2?snippet=%3Cscript%3Ealert
7XSS%27%29%3C%2Fscript%3E HTTP/1.1" 302 -
miko - - [07/Feb/2026 12:40:03] "GET /553395443002625098966819164587306044824/snippets.gtl HTTP/1.1" 200 -
miko - - [07/Feb/2026 12:40:35] "GET /553395443002625098966819164587306044824/ HTTP/1.1" 200 -
miko - - [07/Feb/2026 12:43:08] "GET /553395443002625098966819164587306044824/%3e%3c HTTP/1.1" 200 -
miko - - [07/Feb/2026 12:43:18] "GET /553395443002625098966819164587306044824/%3e%3c HTTP/1.1" 200 -
miko - - [07/Feb/2026 12:43:18] "GET /553395443002625098966819164587306044824/cheese.png HTTP/1.1" 200 -
miko - - [07/Feb/2026 12:43:34] "GET /553395443002625098966819164587306044824/ HTTP/1.1" 200 -
```

Запустил локально Gruyere и на перехватывал трафик выполняя запросы к вебке

Проанализированы полученные запросы и ответы HTTP

```
C:\Windows\System32>python C:\Users\User\Desktop\Python\maga\8\scapy_analyzer.py --capture localhost --timeout 15
[+] Захвачено пакетов: 107
[+] Трафик сохранён в gruyere.pcap
Найдено HTTP-сообщений: 12
HTTP-сообщение 1:
```

Скару для перехвата трафика запускал от имени администратора. Делал два варианта:

- 1) без атаки
- 2) с эксплуатацией XSS

Получил два файла pcap

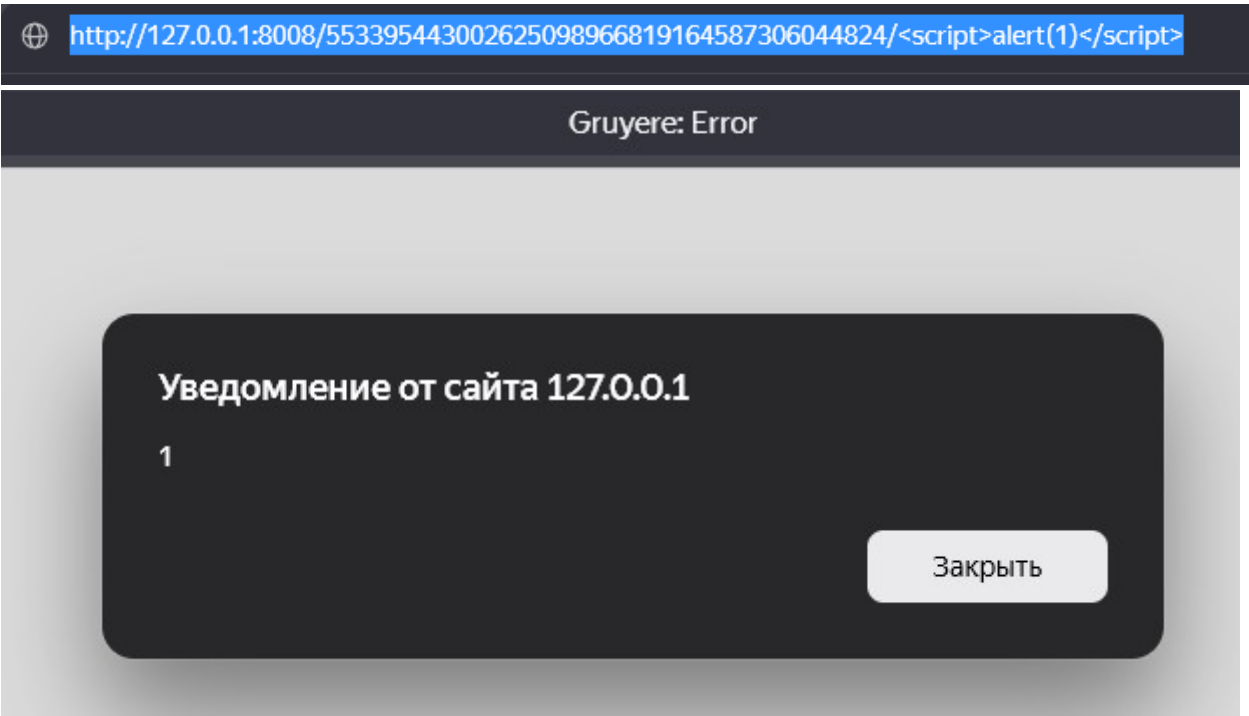
 gruyere	07.02.2026 12:45	Wireshark capture...	24 КБ
 not_attack	06.02.2026 21:56	Wireshark capture...	41 КБ

Проведён рекон-анализ сайта Google Gruyere для поиска потенциальных точек входа XSS

Воспользовался документацией <https://google-gruyere.appspot.com/part2>

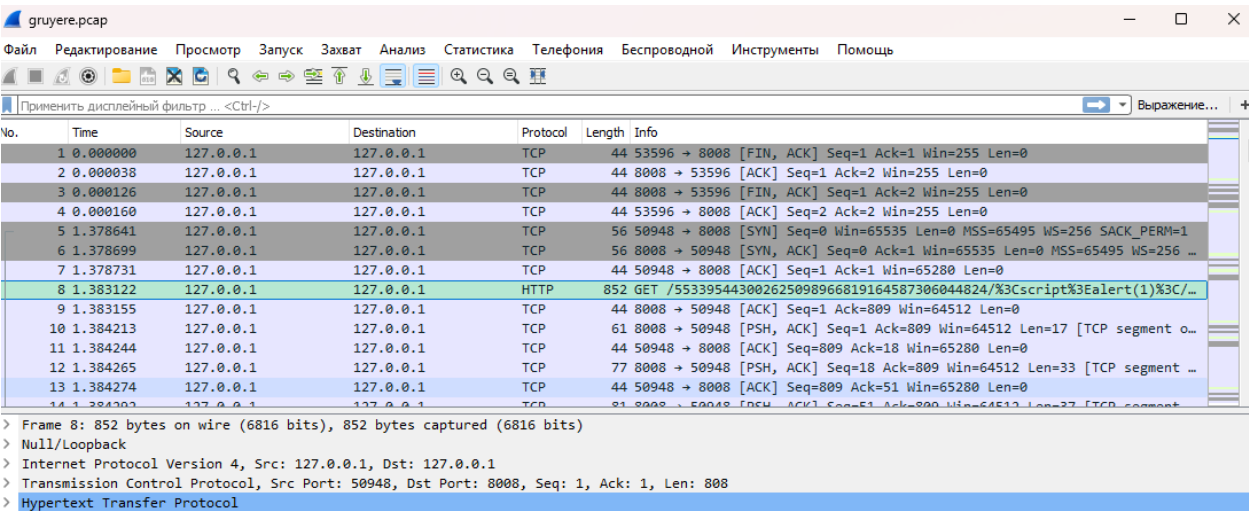
Проведена эксплуатация уязвимости XSS

Код весь дырявый, решил использовать следующую атаку



Найдены следы XSS-атаки в сетевом трафике

На вайршарке



С помощью скрипта

```
PS C:\Users\User> python C:\Users\User\Desktop\Python\maga\8\scapy_analyzer.py --analyze C:\Users\User\Desktop\Python\ma
ga\8\gruyere.pcap
Найдено HTTP-сообщений: 12

HTTP-сообщение 1:
GET /553395443002625098966819164587306044824/%3Cscript%3Ealert(1)%3C/script%3E HTTP/1.1
Host: 127.0.0.1:8008
Connection: keep-alive
sec-ch-ua: "Chromium";v="142", "YaBrowser";v="25.12", "Not_A Brand";v="99", "Yowser";v="2.5"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "Windows"
Upgrade-Insecure-R

HTTP-сообщение 2:
HTTP/1.0 200 OK

HTTP-сообщение 3:
Server: BaseHTTP/0.3 Python/2.7
```

Описаны изменения в трафике, которые произошли во время XSS-атаки

В ходе анализа перехваченного HTTP-трафика было выявлено различие между обычными запросами и запросами с XSS-атакой. В случае XSS-атаки пользовательский ввод, содержащий JavaScript-код, передаётся в HTTP-запросе методом GET и отражается сервером в HTTP-ответе без фильтрации. Это свидетельствует о наличии reflected XSS-уязвимости в веб-приложении Gruyere.

В личном кабинете прикреплён файл с перехваченным трафиком и рабочим скриптом со scapy. Название файла содержит фамилию и имя студента, номер домашнего задания